CASE STUDY

The Microsoft Office Security Feature Bypass of 2026 (CVE-2026-21509) and APT28: A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people who carried this one were the staff and IT teams of Ukrainian central government bodies and of organizations in several European Union countries [9] [10] (**Confirmed**). On Monday 26 January 2026 Microsoft shipped an out-of-band fix for an Office flaw that let a mailed document slip past the protections that keep risky COM/OLE controls from loading, and said it was already being exploited [1] (**Confirmed**). Within three days a lure themed on EU consultations about Ukraine had surfaced, and emails with a weather-bulletin document carrying the exploit had gone to more than 60 addresses, mostly at Ukrainian central executive bodies [9] (**Confirmed**). CERT-UA attributed the attacks to UAC-0001 (APT28) [9] (**Confirmed** as CERT-UA's assessment).

Key facts at a glance

Field	Value
Flaw	Microsoft Office Security Feature Bypass: a bypass of the OLE mitigations for vulnerable COM/OLE controls; CWE-807 [1] [4]
Scoring	CVSS 3.1 7.8 High, AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H; temporal 7.2 (E:F/RL:O/RC:C); Microsoft severity Important [1]
Affected	Office 2016, Office 2019, Office LTSC 2021, Office LTSC 2024, Microsoft 365 Apps for Enterprise, 32-bit and 64-bit [4] [5]
Disclosed	26 Jan 2026, out of band, Exploited = Yes, Publicly Disclosed = No; CVE reserved 30 Dec 2025 [1] [5]
Fix	Service-side change for Microsoft 365 Apps and Office 2021 and later; Office 2016 build 16.0.5539.1001 (KB5002713) and Office 2019 build 16.0.10417.20095 [1] [2] [8]
Credited	MSTIC with MSRC and the Office Product Group Security Team; Google Threat Intelligence Group [2] [3]
KEV	Added 26 Jan 2026, due 16 Feb 2026, known ransomware use Unknown [6]
Actor	UAC-0001 (APT28), per CERT-UA [9]; APT28 "with high confidence", per Zscaler [10]
Targets	Ukrainian central executive bodies; organizations in EU countries; users in Ukraine, Slovakia and Romania [9] [10]

Key findings

- **Exploitation came before the fix and continued after it.** Microsoft marked the flaw exploited when it published on 26 January [1] (**Confirmed**). The earliest dated lure's metadata show creation at 07:43 UTC on 27 January, the day after the notice, and CERT-UA received reports of mailings on 29 January [9] (**Confirmed**). Two domains in the chain were registered on 12 January, two weeks before disclosure, which fits preparation that began before the fix (**Inferred** from [9]).
- **"Local" does not mean hard to reach.** The vector is a mailed document opened once (UI:R); the Preview Pane is not a vector, so the bug is not zero-click [1] (**Confirmed**; the reading is **Inferred**).
- **The cloud fix had a catch.** Microsoft 365 and Office 2021 and later were protected by a service-side change that only took effect after Office restarted [1] (**Confirmed**), so long-running sessions stayed exposed (**Inferred**).
- **The tooling was familiar.** CERT-UA traced the chain to the COVENANT framework talking to the Filen cloud storage service [9] (**Confirmed**); ESET says APT28 has run Covenant over Filen since July 2025 [11] (**Reported**).

Top recommendations

1. Make sure every Microsoft 365 Apps and Office 2021+ session has restarted since 26 January 2026 [1] (**Confirmed** as Microsoft's statement).
2. Move Office 2016 to build 16.0.5539.1001 (KB5002713, MSI) and Office 2019 to 16.0.10417.20095; treat Microsoft's registry COM compatibility block as interim only [1] [8] (**Confirmed**).

3. Block or monitor traffic to Filen hosts, as CERT-UA advises [9] (**Confirmed**), and restrict outbound WebDAV from Office clients (**Inferred** from the chain in [9]).
4. Hunt for COM hijacks of shell-extension CLSIDs, a scheduled task named OneDriveHealth and forced explorer.exe restarts [9] (**Inferred** from CERT-UA's chain).
5. Rank Office "local" bugs by KEV status and delivery path rather than the AV:L label [1] [6] (**Inferred**).

Scope and method

This brief covers CVE-2026-21509 from the CVE reservation on 30 December 2025 to ESET's March 2026 report, with APT28's 2025 tooling as lineage. APT28's earlier record, including CVE-2023-23397 and the advice to block outbound SMB and NTLM, is in Threat Actors: Russia and Fancy Bear Goes Phishing: the cases and is not repeated. Tradecraft is described at advisory level; no indicator lists, registry values or exploit detail are reproduced.

Grade	Meaning in this study
Confirmed	Stated in a primary record opened for this study: Microsoft's advisory, CVRF and KB pages, the CVE, NVD and KEV records, CISA, and CERT-UA (attributions are graded as that agency's assessment)
Reported	A single vendor's account of in-the-wild activity, not independently corroborated (Zscaler, ESET, Sekoia), or anything known only second-hand
Demonstrated	A research proof of concept or a fixed vulnerability with no known in-the-wild use; not used in this study
Inferred	This study's reasoning from cited facts, labelled where it appears

The MSRC page renders only with JavaScript; its content was read through the public MSRC API that serves it [1]. CERT-UA#19542 was read in Ukrainian [9]. Lab52's NotDoor report could not be opened, and no Microsoft or Google write-up of the campaign was located; neither is cited.

Part 1: what happened

Date	Event	Sources	Grade
Jul 2025	APT28's Covenant begins using Filen for command and control, per ESET	[11]	Reported
16 Sep 2025	Sekoia publishes Operation Phantom Net Voxel, the same building blocks (see Part 3)	[12]	Reported
Sep 2025	Lab52 attributes the NotDoor Outlook backdoor to APT28, per Zscaler	[10]	Reported
30 Dec 2025	Microsoft reserves CVE-2026-21509	[5]	Confirmed
12 Jan 2026	Two domains later used in the chain are registered	[9]	Confirmed
26 Jan 2026	MSRC publishes out of band (08:00 PT), Exploited = Yes; revisions 1.0 to 2.1 add the Office 2016 and 2019 updates and set Publicly Disclosed to No; KB5002713 released	[1] [2] [8]	Confirmed
26 Jan 2026	CVE record published 17:06 UTC; NVD 18:16 UTC; KEV adds it with four other CVEs	[4] [5] [6] [7]	Confirmed
27 Jan 2026	COREPER-themed lure created 07:43 UTC (metadata)	[9]	Confirmed
27 to 29 Jan 2026	MSRC revisions 2.2 to 2.4 update the FAQ, the acknowledgements and the mitigation: seven revisions in four days, one leaving contradictory mitigation text (see below)	[1]	Confirmed
29 Jan 2026	The COREPER lure is found in public sources; CERT-UA receives reports of mail posing as Ukraine's Hydrometeorological Center sent to more than 60 addresses	[9]	Confirmed
29 Jan 2026	Zscaler observes in-the-wild exploitation in Ukraine, Slovakia and Romania	[10]	Reported
30 Jan 2026	A domain registered that day is used in an attack; three more exploit documents target EU organizations in late January	[9]	Confirmed
1 Feb 2026	CERT-UA#19542 attributes the activity to UAC-0001 (APT28)	[9]	Confirmed
2 Feb 2026	Zscaler publishes Operation Neusploit	[10]	Reported
10 Feb 2026	KEV adds CVE-2026-21514, a Word flaw with the same CWE-807	[6]	Confirmed
16 Feb 2026	KEV due date for federal agencies	[6]	Confirmed
10 Mar 2026	ESET ties the January campaigns to Sednit's Covenant	[11]	Reported
25 Jun 2026	NVD record last modified	[4]	Confirmed

Discrepancies in the record

- **Two mitigation texts.** The MSRC record carries the registry block for Office 2016 and 2019 and, separately, a text saying the keys do not apply to those versions and leave them unprotected until the update [1] (**Confirmed** that both are present). The second is probably left from an earlier revision (**Inferred**).
- **Word or Office.** The CVE title says Office; KB5002713 calls it "a Microsoft Word security feature bypass vulnerability" [1] [8] (**Confirmed**).
- **DOC or RTF.** CERT-UA describes DOC files [9]; Zscaler describes crafted RTF attachments [10]. An RTF body saved under a .doc name would fit both (**Inferred**).

Part 2: the technical record

The flaw. Microsoft describes reliance on untrusted inputs in a security decision that lets an unauthorized attacker bypass a security feature locally [1] (**Confirmed**). Its FAQ says the update fixes a bypass of the OLE mitigations in Microsoft 365 and Office that protect users from vulnerable COM/OLE controls [1] (**Confirmed**). The attacker must send a malicious Office file and persuade the user to open it; the Preview Pane is not a vector [1] (**Confirmed**). NVD lists CWE-807, shows status Analyzed and carries only Microsoft's vector as Secondary [4] (**Confirmed**). CISA's SSVC entry records Exploitation active, Automatable no and Technical Impact total [5] (**Confirmed**).

The fix. KB5002713 supersedes KB5002573 and does not apply to Click-to-Run [8] (**Confirmed**). For LTSC 2021, LTSC 2024 and Microsoft 365 Apps, Microsoft points to its Office security release notes rather than one build [2] (**Confirmed**). Before the updates, Microsoft offered an interim registry block: a COM Compatibility entry that sets compatibility flags for one CLSID under the Office 16.0 Common key, in four path variants for MSI or Click-to-Run and 32-bit or 64-bit [1] (**Confirmed**). Defenders should take the values from Microsoft's page, not from secondary copies.

The intrusion chain, at advisory level. CERT-UA's analysis [9] (**Confirmed**):

1. Opening the document makes a WebDAV connection to an external resource and fetches a shortcut-format file.
2. That file fetches and runs an executable, which drops a DLL posing as the Enhanced Storage Shell Extension and an image file carrying shellcode.
3. It changes the registry path for one CLSID (a COM hijack) and creates a scheduled task named OneDriveHealth.
4. The task restarts explorer.exe so the hijacked COM object loads the DLL, which runs the shellcode and launches COVENANT.
5. COVENANT uses the legitimate Filen cloud storage service as command and control.

Zscaler describes two payload paths [10] (**Reported**). MiniDoor is an Outlook VBA email stealer that forwards mail to attacker addresses, a stripped-down NotDoor. PixyNetLoader persists through a COM hijack and a scheduled task, hides a shellcode loader in a PNG and runs a Covenant Grunt implant in memory over HTTPS, relayed through the Filen API. The server hands out the next stage only to the targeted regions and the expected User-Agent. Zscaler names detections RTF.Exploit.CVE-2026-21509,

Win64.Dropper.PixyNetLoader, Win32.Backdoor.Covenant and Win32.Spyware.MiniDoor [10] (**Reported**).

Part 3: who and why

CERT-UA. CERT-UA#19542 attributes attacks on Ukraine and EU countries that exploit CVE-2026-21509 to UAC-0001 (APT28) [9] (**Confirmed** as CERT-UA's assessment, not independently verified here).

Zscaler. ThreatLabz names the campaign Operation Neusploit and attributes it to APT28 "with high confidence," citing victimology, MiniDoor's descent from NotDoor, Filen abuse matching Sekoia's Operation Phantom Net Voxel, and overlaps in COM hijacking, DLL proxying and XOR string encryption [10] (**Reported**).

ESET. ESET says Sednit, its name for APT28, deployed Covenant in a series of January 2026 spearphishing campaigns exploiting the flaw, citing CERT-UA [11] (**Reported**).

Lineage. Sekoia's 2025 operation targeted Ukrainian military personnel with Office documents sent over Signal and used the same building blocks: a COM-hijack DLL, PNG steganography, Covenant and cloud storage C2 [12] (**Reported**). Sekoia cites CERT-UA's 21 June 2025 attribution of BeardShell and Covenant to APT28 [12] (**Reported**). In ATT&CK v20.0, APT28 is G0007, attributed to GRU 85th GTsSS military unit 26165, and its only campaign is C0051, the APT28 Nearest Neighbor Campaign [13] [14] (**Confirmed**). The live G0007 page does not mention Covenant, Filen, NotDoor or this CVE [13] (**Confirmed**).

Why. No source states a motive. The lures (EU COREPER consultations on Ukraine, a Ukrainian weather bulletin) and the MiniDoor mail forwarder point to collection against government recipients (**Inferred** from [9] [10]).

Part 4: impact and response

Victims. Beyond the 60-plus addressees, CERT-UA counts one COREPER-themed document and three further documents aimed at EU organizations [9] (**Confirmed**). Zscaler names countries but no sectors [10] (**Reported**). No victim organization is named and no compromise count is given; KEV marks ransomware use Unknown [6] [9] (**Confirmed**).

Microsoft. The advisory names no actor [1] (**Confirmed**). Microsoft credits its own threat-intelligence center and Google's threat-intelligence group [2] [3] (**Confirmed**); two threat-intelligence teams in the credits point to in-the-wild detection (**Inferred**).

CISA and KEV. CISA added the CVE on disclosure day with a 21-day due date of 16 February. The required action is to apply vendor mitigations, follow BOD 22-01 for cloud services, or stop using the product. The notes call for the final mitigations on Office 2021 and the interim ones on 2016 and 2019 until patched [6] (**Confirmed**). The same alert added CVE-2018-14634, CVE-2025-52691, CVE-2026-23760 and CVE-2026-24061 [7] (**Confirmed**).

CERT-UA. CERT-UA urged Microsoft's registry mitigation without delay and the blocking or monitoring of Filen hosts, and forecast more attacks because many users update Office slowly or cannot [9] (**Confirmed**). Whether that rise happened was not checked.

Part 5: the defender and vulnerability-management view

Office documents keep returning to the KEV catalog. It lists Follina (CVE-2022-30190, a Windows MSDT flaw reached through Word documents, added 14 June 2022), the Outlook flaw CVE-2023-23397 (added 14 March 2023, tied to Unit 26165 in Threat Actors: Russia) and, two weeks after this one, CVE-2026-21514, which KEV describes as a local elevation of privilege in Word rather than a bypass [6] (**Confirmed**).

Control	Where it meets the record
Patch 2016 and 2019 by build, not by "updated"	KB5002713 is MSI-only; 2019 is Click-to-Run [2] [8]
Use the registry block only as a bridge	Microsoft and KEV call it interim [1] [6]
Block or monitor Filen; restrict outbound WebDAV	Covenant C2 and the first fetch [9]
Hunt COM hijacks and odd scheduled tasks	OneDriveHealth and the explorer.exe restart [9]
Watch Outlook VBA projects and forwarding	MiniDoor [10]
Sandbox attachments	Zscaler's sandbox caught PixyNetLoader [10]

What is overstated and what is understated

- **Overstated:** reading this as mass exploitation; the record shows targeted spearphishing of government recipients in Ukraine and several EU countries, with no compromise count in any source opened [9] [10] (**Inferred**). Calling it zero-click; the Preview Pane is not a vector [1] (**Confirmed**).
- **Understated:** the AV:L vector, when delivery is one mailed document and one open [1] (**Inferred**); and the speed of new lures after the out-of-band fix: the first dated document was created one day later and mailings were reported three days later, on top of exploitation Microsoft had already detected [1] [9] (**Inferred**). With no victims named, the known targets are a floor, not a count (**Inferred**).

MITRE mappings

This Part binds the record to ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files [14] (**Confirmed** against the MITRE data). Zscaler lists ATT&CK ids [10]; every other row is this study's mapping (**Inferred**). No industrial system is involved, so no ATT&CK for ICS table applies.

Groups, software and campaigns

Object	ATT&CK id	Relationship to this record
APT28	G0007	Attributed by CERT-UA (1 Feb), Zscaler (2 Feb) and ESET (10 Mar) [9] [10] [11]
Covenant	S1155	The final payload [9] [10]; ATT&CK links it only to HAFNIUM (G0125; see Operation Exchange Marauder) [13]
APT28 Nearest Neighbor Campaign	C0051	Lineage only: APT28's sole ATT&CK campaign [14]

ATT&CK has no object for MiniDoor, PixyNetLoader, NotDoor, BeardShell, Operation Neusploit or Phantom Net Voxel [14] (**Confirmed** against the MITRE data), so none is bound.

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1583.001	Domains	Resource Development	Domains registered 12 and 30 Jan (CERT-UA)	[9]
T1566.001	Spearphishing Attachment	Initial Access	Hydrometeorological Center mailing, 29 Jan; RTF attachments (Zscaler)	[9] [10]
T1203	Exploitation for Client Execution	Execution	CVE-2026-21509 exploited (MSRC, 26 Jan)	[1] [10]
T1204.002	Malicious File	Execution	User must open the file (MSRC, 26 Jan)	[1] [10]
T1105	Ingress Tool Transfer	Command and Control	WebDAV fetch of shortcut and executable (CERT-UA, 1 Feb)	[9]
T1036.005	Match Legitimate Resource Name or Location	Stealth	DLL posing as the Enhanced Storage Shell Extension (CERT-UA, 1 Feb)	[9]
T1036.004	Masquerade Task or Service	Stealth	Task named OneDriveHealth (CERT-UA, 1 Feb)	[9]
T1546.015	Component Object Model Hijacking	Privilege Escalation, Persistence	COM hijack of a shell-extension CLSID (CERT-UA, 1 Feb; Zscaler, 2 Feb)	[9] [10]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	OneDriveHealth restarts explorer.exe (CERT-UA, 1 Feb)	[9] [10]
T1027.003	Steganography	Stealth	Shellcode in an image (CERT-UA, 1 Feb; Zscaler, 2 Feb)	[9] [10]
T1102.002	Bidirectional Communication	Command and Control	Filen as C2 (CERT-UA, 1 Feb)	[9] [10]
T1071.001	Web Protocols	Command and Control	Grunt over HTTPS (Zscaler, 2 Feb)	[10]
T1114	Email Collection	Collection	MiniDoor forwards mail (Zscaler, 2 Feb)	[10]
T1137	Office Application Startup	Persistence	MiniDoor's VbaProject.OTM loads at Outlook startup (Zscaler, 2 Feb)	[10]
T1140	Deobfuscate/Decode Files or Information	Stealth	Shellcode decoded from the PNG; XOR-decrypted strings (Zscaler, 2 Feb)	[10]
T1106	Native API	Execution	Native APIs run the Variant 2 shellcode (Zscaler, 2 Feb)	[10]
T1027.007	Dynamic API Resolution	Stealth	DJB2 API hashing in the Variant 2 loader (Zscaler, 2 Feb)	[10]
T1497.003	Time Based Checks	Stealth, Discovery	Loader checks that Sleep is not short-circuited (Zscaler, 2 Feb)	[10]
T1480.002	Mutual Exclusion	Stealth	Droppers create named mutexes (Zscaler, 2 Feb)	[10]

Fit notes (**Inferred**): T1203 is Zscaler's choice for a feature bypass rather than memory corruption. T1036.004 reads the OneDriveHealth name as imitation. Zscaler lists T1137.006 (Add-ins); this study binds the parent

T1137 because a VbaProject.OTM loaded at Outlook startup sits between Office Template Macros and Add-ins. Zscaler's server-side geofencing by region and User-Agent has no exact ATT&CK technique and is not bound. T1106, T1027.007, T1497.003 and T1480.002 rest on Zscaler's analysis alone.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-807	Reliance on Untrusted Inputs in a Security Decision	CVE-2026-21509 (MSRC, CNA, NVD, KEV)	[1] [4] [6]

CAPEC	Name	Via	Where it meets the record
CAPEC-163	Spear Phishing	T1566.001	The lure mailings [9]
CAPEC-504	Task Impersonation	T1036.004	OneDriveHealth [9] (**Inferred** fit)
CAPEC-636	Hiding Malicious Data or Code within Files	T1027.003	Shellcode in an image [9]

The library relates no CAPEC to CWE-807 [14] (**Confirmed** against the MITRE data). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to	Where it meets the record
Email Filtering, Sender Reputation Analysis	T1566.001	Spoofed government senders [9]
Dynamic Analysis	T1204.002, T1566.001	Sandbox detection of PixyNetLoader [10]
Outbound Traffic Filtering	T1105, T1071.001	Blocking Filen and the WebDAV fetch [9]
System Configuration Permissions	T1546.015	COM hijack [9] [10]
Scheduled Job Analysis	T1036.004	OneDriveHealth [9]
Process Lineage Analysis	T1053.005	Task-driven explorer.exe restart [9]

Microsoft's COM compatibility block corresponds to Application Configuration Hardening, which the library does not relate to these techniques [1] [14] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer pinned to ATT&CK v20, `navigator/library-layers/microsoft-office-cve-2026-21509.json` (open in Navigator), listed on the Navigator layers page. Each technique appears under every tactic in its library profile. Scores: 75 for behavior in a Microsoft or government record, 50 for a vendor research report, 25 for an inexact fit. Each comment names its source numbers.

Cross-cutting themes

- **Disclosure did not slow the actor.** A lure's metadata show it was created the day after Microsoft's notice [9] (**Confirmed**), and Microsoft had already detected exploitation [1] (**Confirmed**); domains registered on 12 January suggest the campaign was prepared before the fix (**Inferred**).
- **Cloud storage is the new command channel.** Filen here, Koofr and icedrive in 2025 [9] [12]; blocking one host is a stopgap (**Inferred**).
- **Security features are attack surface.** A bypass of a protection layer earns Important, not Critical, yet it opened the door [1] (**Inferred**). Vulnerability Root Causes covers the pattern.
- **Advisories are living documents.** The MSRC record changed seven times in four days (Part 1) [1] (**Confirmed**); defenders should re-read an out-of-band advisory before acting on it (**Inferred**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	Microsoft MSRC, CVE-2026-21509 Security Update Guide entry, 26 Jan 2026, revision 2.4 of 29 Jan 2026 (read through the MSRC API)	msrc.microsoft.com/update-guide/vulnerability/CVE-2026-21509	2026-11-11	Confirmed
2	Microsoft MSRC, CVRF document 2026-Jan	api.msrc.microsoft.com/cvrf/v3.0/cvrf/2026-Jan	2026-11-11	Confirmed
3	Microsoft MSRC, acknowledgement record for CVE-2026-21509	api.msrc.microsoft.com/sug/v2.0/en-US/acknowledgement	2026-11-11	Confirmed
4	NVD, CVE-2026-21509	nvd.nist.gov/vuln/detail/CVE-2026-21509	2026-11-11	Confirmed
5	CVE Program record CVE-2026-21509 (CNA Microsoft; CISA ADP SSVC)	cve.org/CVERecord?id=CVE-2026-21509	2026-11-11	Confirmed
6	CISA, Known Exploited Vulnerabilities catalog, entry and JSON version 2026.11.10	cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-21509	2026-11-11	Confirmed
7	CISA, CISA Adds Five Known Exploited Vulnerabilities to Catalog, 26 Jan 2026	cisa.gov/news-events/alerts/2026/01/26/...	2026-11-11	Confirmed
8	Microsoft Support, KB5002713, security update for Office 2016, 26 Jan 2026	support.microsoft.com/help/5002713	2026-11-11	Confirmed
9	CERT-UA, CERT-UA#19542, 1 Feb 2026 (Ukrainian)	cert.gov.ua/article/6287250	2026-11-11	Confirmed
10	Zscaler ThreatLabz (Sudeep Singh, Roy Tay), APT28 Operation Neusploit: CVE-2026-21509 RTF Exploit, 2 Feb 2026	zscaler.com/blogs/security-research/...	2026-11-11	Reported
11	ESET Research, Sednit reloaded: Back in the trenches, 10 Mar 2026	welivesecurity.com/en/eset-research/sednit-reloaded-back-trenches/	2026-11-11	Reported
12	Sekoia TDR, APT28 Operation Phantom Net Voxel, 16 Sep 2025	sekoia.com/blog/apt28-operation-phantom-net-voxel	2026-11-11	Reported

#	Source	URL	Opened	Grade
13	MITRE ATT&CK, APT28 (G0007) and Covenant (S1155) pages	attack.mitre.org/software/S1155/	2026-11-11	Confirmed
14	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), and `data/weaknesses/cwe.jsonl` and `capec.jsonl`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Confirmed

Not opened, so not cited as sources: Lab52's NotDoor report (connection failed), and any Microsoft, Google, CERT-EU or national-agency write-up of the campaign (not located).

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors: Russia, Fancy Bear Goes Phishing: the cases, Sandworm Operations, Operation Exchange Marauder, The Year 2026 in Intrusions, Timeline
- Other 2026 Microsoft studies: The SharePoint Server exploitation waves of 2026
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Email Security Reference, Windows Hardening Reference, Windows, Vulnerability Management Reference, Vulnerability Prioritization Reference
- MITRE objects: G0007 APT28, S1155 Covenant, C0051 APT28 Nearest Neighbor Campaign; techniques, CAPEC and D3FEND pages are linked in the MITRE mappings Part
- Navigator layers, including this study's layer, microsoft-office-cve-2026-21509.json
- The Team Star Wolf Intelligence Hub
- All case studies